

Bu kitapta; bilgi sistemleri güvenliğine ilişkin bilgi güvenliği ve varlık yönetimi ele alınarak ağ güvenliği, erişim güvenliği, fiziksel ve çevresel güvenlik, veri ve iz kayıtlarının güvenliği ve üçüncü taraflarla iletişim güvenliği konularına yer verilmektedir.

1. BİLGİ GÜVENLİĞİ YÖNETİMİ

1.1. Kavram

İlk başta teknolojik ekipmanların fiziksel güvenliğiyle başlayan bilgi güvenliği konusu bugün siber güvenlik olarak kapsamı genişlemiş ve sadece BS birimlerini değil, kurumları, ülkeleri ve uluslararası organizasyonları da etkilemeye başlamıştır. Ülkemizde kurumsal düzeyde gerek kamu gerekse de özel sektör bağlamında çeşitli strateji, eylem planları, düzenleme ve rehberler seviyesinde birçok mekanizma ile makul bir güvence oluşturulmaya çalışılmaktadır. Bu konuda en yaygın örneklerden biri Uluslararası Standartlar Örgütü (ISO) tarafından yayınlanan ve her türden kurum için uygulanabilir olan Bilgi Güvenliği Standardıdır (ISO 27001:2013).

Bilgi güvenliği yönetimi, kurumda bilgi güvenliğinin kabul edilebilir düzeyde korunmasını sağlamak amacıyla geliştirilen ve kullanılan tüm mekanizmalardır. Bunlar; organizasyonel yapılar, politika ve prosedürler, süreçlerdir ve çeşitli varlıklardır. Bilgi güvenliğinde amaç bilginin aşağıda verilen üç temel özelliğini korumaktır (ISO, t.y.):

- Gizlilik (confidentiality): Bilgiye izinsiz erişimlerin engellenmesi.
- Bütünlük (integrity): Bilginin tam ve doğru olması.
- Erişilebilirlik (availability): Bilginin ihtiyaç duyulduğunda yetkili taraflarca erişilebilir olması.

Bilgi güvenliği, temel olarak bilginin gizliliği, bütünlüğü ve erişilebilirliği ilkeleri doğrultusunda korunmasını hedefleyen bir yönetim disiplini. Bilgi güvenliği yaklaşımına ek olarak siber güvenlik kavramı da literatürde yaygın olarak yer almakta ve çoğu zaman bu iki kavramın birbirlerinin yerine kullanıldığı görülmektedir. Bu çerçevede, siber güvenlik ve bilgi güvenliği kavramları arasındaki ilişkiyi daha iyi anlayabilmek adına, siber güvenliğe ilişkin çeşitli tanımlara aşağıda yer verilmiştir. (Alexei & Alexei, 2023)

NIST, siber güvenliği; sürekli izleme, analiz ve müdahale gerektiren bilgi sistemlerine yönelik dinamik bir koruma süreci olarak ele alır ve kavramı şöyle ifade eder:

“Saldırıları önleyerek, tespit ederek ve bunlara yanıt vererek bilgileri koruma süreci.”

ISO/IEC 27100 standardında siber güvenlik aşağıdaki gibi açıklanır:

“İnsanların, toplumun, kuruluşların ve ulusların siber risklerden korunması.”

Bragaru ve Briceag tarafından ISO/IEC 27032 standardından uyarlanan tanım ise şu şekildedir:

“Teknolojik cihazlar veya entegre ağlar aracılığıyla sağlanan İnternet hizmetleri, insanlar ve yazılımlar arasındaki etkileşim sürecinde ortaya çıkan karmaşık bir ortam olan siber uzayla ilgili her türlü güvenlik.”

Bu tanım, siber güvenliğin yalnızca teknik bir konu olmadığını, aynı zamanda insan ve süreç faktörlerini de kapsadığını ortaya koymaktadır. Söz konusu siber güvenlik tanımında yer alan siber uzay kavramı ise ISO/IEC 27100 standardında;

“Ağların, hizmetlerin, sistemlerin, insanların, süreçlerin, organizasyonların ve dijital ortamda bulunan veya dijital ortamdan geçen her şeyin birbirine bağlı dijital ortamı (Bu ortam, şirket iç ağına ait bölümlerden veya herkese açık ağlarla bağlantısı olmayan, yalıtılmış (air-gapped) dijital ortamlardan ziyade İnternet gibi kamusal altyapılar üzerinden geçen, birbirine bağlı dijital ortamı ifade eder)”

olarak tanımlanırken, NIST siber uzayı şu şekilde tanımlar:

“İnternet, telekomünikasyon ağları, bilgisayar sistemleri ile gömülü işlemciler ve denetleyicileri kapsayan bilgi sistemleri altyapılarının birbirine bağlı ağının oluşturduğu, bilgi ortamı içinde yer alan küresel bir alan.”

Siber uzay kavramı, siber güvenliğin kapsamını anlamak açısından oldukça önemlidir; çünkü siber güvenlik tanımlarında siber uzayın güvenliğinin sağlanması üzerinde durulmaktadır. Bu kapsamda koruma altına alınan alanın sadece bilgi değil, bu bilginin işlendiği ve aktarıldığı bilgi sistemlerinin de yer aldığı görülmektedir.

Von Solms ve van Niekerk ise siber güvenliği şöyle açıklar:

“Siber uzayın kendisinin, elektronik bilgilerin, siber uzayı destekleyen bilgi ve iletişim teknolojilerinin ve siber uzay kullanıcılarının, siber uzay kaynaklı saldırılara karşı savunmasız olan somut ya da soyut çıkarlarından herhangi biri dahil olmak üzere, kişisel, toplumsal ve ulusal kapasitelerde korunmasıdır.”

Bu tanımla; siber güvenliğin birey, kurum, toplum, devlet gibi çok farklı alanlarda ele alındığını ve bu anlamda bireysel hakların korunmasından ulusal güvenliğe uzanan bir güvenlik yaklaşımı olduğu vurgulanmaktadır. Günümüzde siber uzay, birçok ülke tarafından ulusal güvenlik için kara, hava, deniz ve uzayla birlikte stratejik bir alan olarak kabul edilmektedir.

Diğer yandan Edgar ve Manz, siber güvenliği şu şekilde ifade eder:

“Siber uzayda bir şeyin güvenliğini sağlamaya yönelik teknolojileri, politikaları ve prosedürleri içeren bir alan.”

Bu yaklaşım, siber güvenliğin sadece teknolojik değil, aynı zamanda yönetsel ve prosedürel bileşenleri de içeren çok boyutlu bir kavram olduğunu belirtmektedir.



Şekil 1: Bilgi güvenliği ve Siber Güvenlik

Özetle; bilgi güvenliği, bilginin gizliliğini, bütünlüğünü ve erişilebilirliğini sağlamak amacıyla uygulanan idari, teknik ve fiziksel kontrolleri kapsar. Bilgi güvenliğinde bilginin korunmasına büyük önem verilmekte, bu amaçla hem dijital hem de fiziksel ortamlarda bulunan tüm bilgi varlıkları ele alınmaktadır. Siber güvenlik ise, özellikle İnternet üzerinden gerçekleştirilen saldırılara ve siber tehditlere karşı savunma önlemlerini içerir. Siber güvenlikle İnternete bağlı ağlardaki veri ve sistemlerin korunması amaçlanır. Siber güvenlikte siber uzayın parçası bütün varlıkların korunmasına yönelik tedbir alınır. Bu kapsamda bilgi sistemleri ve üzerindeki veriler temel olarak koruma altına alınır.

Bu bağlamda, bilgi güvenliği ve siber güvenlik arasındaki temel fark, odak noktalarındadır. Bilgi güvenliği daha çok bilginin kendisinin korunmasına odaklanırken, siber güvenlik bu bilginin yer

aldığı dijital altyapılar, ağlar, cihazlar ve sistemlerin bütünsel güvenliğini esas alır. Ancak pratikte bu iki kavram birbirini tamamlayarak çalışır ve güçlü bir güvenlik stratejisi için birlikte ele alınmalıdır.

Kurumsal düzeyde bilgi güvenliği nereden başlar, bu konuda aksiyon almak isteyen bir kurumun işe hangi standart/rehber/düzenlemeden başlamalıdır sorusunun cevabı olarak başlangıç noktası bilginin kurum için önemini idrak etmek ve “korunması gereken bir varlık” olarak görülmesini sağlamaktır denilebilir.

Geleneksel olarak hiçbir kurum -en azından henüz bilgi güvenliği kavramı çok yaygınlaşmadan önce- varlıklarını “sayarken” veya “envanterini gözden geçirirken” bilgiyi aklına getirmemiştir. Çünkü bilgi hem sayılabilen bir kavram değildir, hem de zaten ya kağıt üzerinde dosyaların içinde ya da bilgisayardadır. Tek başına bir varlık/değer olarak görülmemiştir. Ancak teknolojinin görece ucuzlaması, herkese ulaşması, son kullanıcıya yönelik çözümlerin çok yaygınlaşması sebebiyle artık kurumlar bilgiyi yine bir varlık olarak tanımlamasa bile öneminin farkında ve önemli olan her şey gibi bilginin de korunması/yönetilmesi gerektiğini bilmektedir.

Bilgi güvenliği yönetiminde belirli bir rehber/yönetim çerçevesi/standart takip edilebilir. Bu durumda ilgili düzenlemenin gerektirdiği yol izlenmelidir. Bu karar üst yönetim tarafından verilmelidir. Bilgi güvenliğinde genel yaklaşım aşağıdaki gibi özetlenebilir ancak seçilen yöntemle göre bazı farklılıklar olabilir.

1.2. Üst Yönetimin Bilgi Güvenliği Sorumluluđu

Bilgi güvenliği teknik bir iş değildir ve kurumun her kademesini ve her çalışanını ilgilendirir. Kurumda bu işin sorumluluğunun en üstte olması beklenmektedir. Bilgi güvenliği politikasının oluşturulması ve her yıl gözden geçirilmesi, bu kapsamda görevlendirmelerin yapılması, risk yönetiminin gerçekleştirilmesi, çalışanlarının farkındalığının sağlanması, bilgi güvenliği ihlallerinin değerlendirilmesi üst yönetime verilmiş sorumluluklardır. Üst yönetim/yönetim kurulu aldığı/alacağı kararlar, uygulama tarzı ve bizzat bireysel yaklaşımıyla bu konuya verdiği önemi göstermelidir.

1.3. Roller ve Sorumluluklar

Üst yönetim tarafından bu konuyla görevlendirilmiş en az bir kişinin (tek görevi bu olmayabilir) sorumlu olarak belirlenmesi (bilgi sistemleri güvenliği sorumlusu), ayrıca kurumun büyüklüğüne göre bir ekibin de oluşturulması doğru olacaktır. Ekte kurumdaki her birimden en az bir temsilcinin yer alması önemlidir. Oluşturulan bu ekibin çalışma yönteminin kararlaştırılması, ekipçe alınan kararların birimlerde/kurumda uygulanabilir olmasını sağlayacak mekanizmanın belirlenmesi, ekte görev dağılımı yapılması gerekir. Ekte birimleri temsilen bulunanların, kendi birimindeki çalışmaları/fonksiyonları bilgi güvenliği ilkeleri özelinde gözden geçirecek ve gerekirse revize edecek/edilmesini sağlayacak yetkinlikte olması da önemli olan bir diğer unsurdur.

Bilgi güvenliği kapsamındaki her rolün görev tanımları yazılı, onaylı ve ilgililere duyurulmuş olmalıdır. Bilgi güvenliğinden sorumlu kişi ve kişiler kurum organizasyon şemasında yer almalıdır.

1.4. Farkındalık ve Eğitim

Bilgi güvenliği konusunda kurumların farkındalık yaratmak ve çalışanlarını eğitmek sorumluluđu bulunmaktadır. Tüm seviyedeki çalışanlara temel bilgi güvenliği eğitimi verilmeli, farkındalık sağlanmalı, zaman zaman konu hakkında bilgilendirmeler yapılmalıdır. Farkındalığın ve konuya verilen önemin sürdürülmesini teminen düzenli aralıklarla eğitimler tekrar edilmelidir. Ancak, eğitimlerin içeriği eğitim verilecek gruba göre düzenlenmeli ve güncel gelişmeleri de içermelidir.

1.5. Bilgi Güvenliđi Politikası

Kurumlar bilgi güvenliđini uygulama yaklařımı her ne řekilde olursa olsun, bir bilgi güvenliđi politikası oluřturmalıdır. Bilgi güvenliđi politikası bu konuda üst yönetimin genel yaklařımını, konuya verilen önemi, kapsamı belirlemelidir. Diđer politikalar gibi üst yönetimce onaylanmalı, uygun řekilde duyurulmalı, çalışanların erişebilecekleri yerde olmalıdır. Belirli periyotlarda ve gerektiğinde periyot dışında gözden geçirilmeli ve tekrar onaylanıp duyurulmalıdır.

Bilgi güvenliđi politikası ařağıdaki hususları ele almalıdır:

- Bilgi güvenliđinin tanımı, kapsamı, kurumsal bilgi güvenliđi hedefleri
- Bilgi güvenliđi ile ilgili kurumsal roller ve sorumluluklar
- Risk yönetimi
- Tabii olunan diđer düzenlemeler
- Bilgi güvenliđi farkındalıđı ve eđitimi
- Üst yönetimin bađlılıđı/bakıřı
- Bilgi güvenliđi politika ve süreçlerine aykırı davranmanın olası sonuçları

İřletmede bilgi güvenliđi faaliyetlerinin sadece çalışanları deđil tedarikçileri, servis sağlayıcıları, müşterileri, iř ortakları kısaca dıř paydařları da etkileyeceđi ve kurumun bilgi güvenliđi hususlarının bunlardan etkileneceđi dikkate alınmalı ve söz konusu politika uygun yöntemlerle paydařlara duyurulmalıdır.

Bu kapsamda bilgi güvenliđine yönelik gerekirse destek politikaları oluřturulabilir. Bunlar kurumun genelinden ziyade belli bir birimi/iř sürecini hedef alabilir ve söz konusu birim/iř süreci bazında bilgi güvenliđi ilkelerini düzenleyebilir veya ayrı politika dokümanları yerine tek bir bilgi güvenliđi politikası da düzenlenebilir. Bu seçimde kurumun büyüklüğü, faaliyetlerin çeřitliliđi, çalışan sayısı bir parametre olarak kabul edilebilir.

1.6. Risk Yönetimi

Bilgi güvenliđi yönetiminin ayrılmaz bir bileřeni olan bu konu, 1020 nolu “*Bilgi Sistemleri Yönetimi ve Denetimi*” bařlıklı çalışma notunda iřlenmiřtir. Burada kısaca tekrar etmek gerekirse bilgi sistemleri kapsamında risk yönetimi, bilgi sistemleri kullanımından kaynaklanan risklerin yönetilmesi ve bu konuda makul bir güvence sađlanması amacını tařır. Bu süreçle bilgi sistemlerine ait envanterde kayıtlı olan her tür varlıđın maruz kaldıđı risklerin yönetilmesi, dolayısıyla bunlar aracılıđıyla iř süreçlerinin sürekliliđi ve kurumsal bilginin uygun řekilde korunması amaçlanmaktadır. Risk yönetimi sürecinde ilk adım olarak belirtilen varlıkların tespiti ařamasında ařağıdaki belirtilen çerçeve dikkate alınmalıdır:

- Sunucu donanımları, depolama ortamları
- Kullanıcı cihazları (bilgisayar, tablet, akıllı cihazlar)
- Ađ cihazları
- Her türden yazılım

Burada “veri” ayrı bir varlık olarak gösterilmemiřtir ancak yukarıda sayılan bilgi sistemlerini korumanın amacı esasında bu varlıklar aracılıđıyla iřlenen, saklanan ve iletilen veriyi korumaktır. Varlıkların belirlenmesi ařamasından sonra bu varlıkların her birinin yapısından veya kullanımından kaynaklanan her türlü zafiyet (vulnerability) tespit edilmelidir. Zafiyetlerin her biri birer istismar (exploit) noktası olduđundan bu zafiyetlerden yararlanabilecek tehditler belirlenmelidir. Bu řekilde, bilgi güvenliđi riskinin üç temel noktası tespit edilmiř olur ki bu risk belirleme süreci (risk identification) olarak tanımlanmaktadır.

Bu noktadan sonra risk değerlendirmesi yapılmalıdır. Buna ilişkin çeşitli yöntemler mevcuttur. Kurum risk değerlendirme yöntemini seçmekte özgürdür. Ancak seçilen yöntemle ilgili belli bir bilgi birikimi oluşmalı ve tüm süreç buna uygun işletilmelidir.

Daha önce de belirtildiği gibi, kurumun risk yönetiminden hedefi sıfır riskli bir ortam olmamalıdır. Kurum tarafından belirli bir risk seviyesi eşik değer olarak belirlenmeli (kabul edilebilir risk değeri, risk iştahı), buna göre bu seviyenin üzerinde kalan riskler için risk işleme çalışması yapılmalıdır. Kontrolün maliyeti riskin olası maliyetini aşmamalıdır (buradaki istisna kontrolün yasal mevzuat tarafından zorunlu tutulmasıdır). Risk işleme seçenekleri aşağıda belirtilmiştir:

- **Riski azaltma**

Çeşitli kontroller yardımıyla riskin düşürülmesi. En çok tercih edilen seçenektir. Bu noktada bilgi sistemleri risklerine karşı geliştirilecek kontroller çok çeşitlidir ve politika, prosedür, talimat, yazılım, donanım gibi unsurları içerir. Seçilen rehber/yönetim çerçevesi/standartta bu konuda yardımcı olması amacıyla örnek kontrol listeleri olabilir.

- **Riski engelleme**

Riske sebep olan ürünün/hizmetin kullanımına son verme. Kontrollerle düşürülemeyecek risklerin tamamen engellenmesidir.

- **Riski paylaşma**

Riski üçüncü taraflarla paylaşma. Örneğin sigorta yaptırılması. Ancak bu seçenek riskin gerçekleşmesi olasılığını değiştirmemektedir.

- **Riski kabul etme**

Riske rağmen ürünün/hizmetin kullanımına devam etme. En kötü seçenek olarak değerlendirilir çünkü riski bilinen bir ürünü/hizmeti hiçbir şey yapmadan kullanıma devam etmektir.

Risk değerlendirme aşamasında gerekli yazılı dokümanlar oluşturulmalıdır. Bu dokümanlar asgari olarak risk değerlendirmede seçilen yöntemi, kabul edilen risk değerini, tüm varlıkların risk analiziyle beraber risk değerlerini, kabul edilebilir risk seviyesinin üzerinde kalan riskler için seçilen risk işleme yöntemini içermelidir.

Risk değerlendirme çalışması periyodik aralıklarla yenilenmelidir. Bunun dışında, bilgi sistemleri risklerinde önemli değişimlere sebep olacak (olumlu veya olumsuz) durumlarda da risk değerlendirmesi yenilenmelidir.

1.7. Bilgi Güvenliği Gözetimi, Ölçümü ve Değerlendirmesi

Bilgi güvenliği konusunda periyodik olarak gözetim, ölçüm ve değerlendirme yapılmalıdır. Bu kapsamda; uyulan tüm yasal düzenlemeler, standartlar, çerçeveler veya rehberler için söz konusu işlemlerin gerçekleştirilmesi gerekmektedir. Gözetim, ölçüm ve değerlendirme faaliyetinde amaç bilgi güvenliği kapsamında işletilen süreçlerin etkinliğini tespit etmek, bilgi güvenliği hedeflerinin başarımını ölçmek, risk değerlendirme sürecini ve risklere cevaben geliştirilen kontrollerin etkin ve işler olup olmadığının değerlendirilmesini sağlamaktır.

Bilgi güvenliği ölçümleri için oluşturulan kontroller, ölçüt değerleri (KPI) ve risk değerlendirmeleri kapsamında iç ve dış denetimlerle doğrulanabilir. Bununla birlikte; teknik açıklıklar ve işleyişe ilişkin kısımlar, çeşitli senaryo uygulamaları, kırmızı-mavi takım alıştırma ve sızma testleri ile test edilebilir. Bilgi sistemlerinde yer alan açıklıkların ve zafiyetlerin önceden tespit edilmesi ve düzeltilmesi faaliyeti olan sızma testi, Sermaye Piyasası Kurulu Bilgi Sistemleri Yönetimine İlişkin Usul ve Esaslar Tebliği (VII-128.10) (BSY Tebliği) uyarınca da (muaf olanlar hariç) yılda en az 1 kere gerçekleştirilmektedir.

Sızma testlerine yönelik tek bir standart bulunmamakla birlikte, uygulamada benzer yöntemler ve araçların kullanımı ön plana çıkmaktadır. Bununla birlikte, BSY Tebliği ekinde yer alan “Bilgi Sistemleri Sızma Testleri Usul ve Esasları” taahhidi olmayan genel bir çerçeve belirlemektedir. Bu kapsamda;

- Sistemlere ilişkin hangi tip ön bilginin paylaşıldığı (Şirket tarafından sızma testini gerçekleştirecek taraflara sistemlere ilişkin hiç bilgi verilmeyen siyah/kapalı kutu (black box), test edilecek sistemlere yönelik bilgilerin sağlandığı beyaz/açık kutu (white box) veya kısmi bilgi sağlanan gri/şeffaf kutu (gray box) gibi farklı uygulamalar olabilir),

- Hangi sistemlere yönelik sızma testi gerçekleştirildiği (Altyapı, servisler, cihazlar, uygulamalar, sosyal mühendislik vd.),

- Hangi erişim noktalarının kullanıldığı (Internet, intranet (iç ağ), diğer ağlar),

- Hangi kullanıcı profillerinin test edildiği,

- Ayrı ayrı her bir bulgunun etkisi,

- Bulguların beraber değerlendirilmesinde etkisi

hususlarının sızma testi raporunda yer alması gerekmektedir. Bu kapsamda gerçekleştirilen sızma testi sonucunda tespit edilen bulgular etki seviyesine göre değerlendirilip raporlanmalıdır.

1.8. Bilgi Güvenliği İhlal Yönetimi

Bilgi güvenliği ihlali bilgi sistemlerinde sonucu itibariyle bilgi veya bilgi barındıran ortamlarda bir zarara sebep olmuş veya olma ihtimali çok yüksek herhangi bir olay olarak tanımlanabilir. Bu bir arıza, yanlış kullanım, suiistimal, dışarıdan bir saldırı olabilir. İhlal olarak değerlendirilmesi için bilgi güvenliğini tehlikeye atmış olması yeterlidir.

Kurumda her çalışan –aldığı eğitim ve dikkati sayesinde- bir ihlali veya ihlalin belirtisini tespit edebilir, farkına varabilir. İşte bu yüzden tüm çalışanların bu tespitlerini veya şüphelerini konunun uzmanı kişilere iletebileceği bir mekanizma kurulu ve işler durumda olmalıdır. Bu bir çağrı hattı, bir yardım masası uygulaması, belli bir e-posta hesabı veya buna benzer bir yöntem olabilir. Önemli olan kurumun tümünde yaygınlaşmış olması, her seviyede personelin kullanabileceği basitlikte olması ve bu konuda tüm personelin bilgilendirilmiş olmasıdır. Hangi yöntemle yapılırsa yapılsın tüm çağrılarının analiz edilmesi, gerekirse ilgili ekiplere yönlendirilmesi, çağrının sonucu konusunda çağrıyı yapan kişiye geri bildirimde bulunulması gerekmektedir. En az bir çalışan bu işle görevlendirilmiş olmalıdır.

Herhangi bir ihlal meydana geldiğinde işletilecek mekanizmalar ve tüm sorumluluklar yazılı ve onaylı olarak belirlenmiş, gerekli görevlendirmeler önceden yapılmış olmalıdır.

Bilgi güvenliği ihlali sadece çalışanlar tarafından fark edilmez. Esas olarak çeşitli gözetim mekanizmalarından elde edilen verilerin analiz edilmesiyle ortaya çıkarılır. Burada gözetim altında tutulacak birçok veri kaynağı, analiz yaparken kullanılacak da birçok ürün mevcuttur. Kurum kendi yapısı ve faaliyetlerinin çeşitliliğine uygun mekanizmaları kurmuş olmalıdır. Gözetim ve analizle ilgili sorumluluklar belirlenmelidir. Bu konuda detaylı bilgi “*Veri ve İz Kayıtlarının Güvenliği*” bölümünde mevcuttur.

Gözetim ve kurum içindeki geri bildirimlerden elde edilen veri değerlendirilmeli ve gerçekten bir bilgi güvenliği ihlali olup olmadığına karar verilmelidir.

Bilgi güvenliği ihlalinin gerçekleştiğine karar verilirse çeşitli iletişim mekanizmalarıyla gerekli iç ve dış bilgilendirmeler (bilmesi gereken ilkesine göre-need to know) yapılmalıdır. Dış bilgilendirme müşterileri ve hukuki mercileri içerebilir.

Kurum bünyesinde “Kurumsal Siber Olaylara Müdahale Ekibi” yer alıyorsa, ihlal bildirimlerinin bu ekip tarafından ele alınması gerekir. İhlalin türüne ve etkisine göre başka ekipler de devreye girebilir.

İhlalin fark edilmesinden sonraki en önemli süreç “kanıt toplama” sürecidir. Bu konuda izlenecek yolun mutlaka önceden belirlenmiş olması gerekir. Kanıt toplama sürecinin doğru şekilde yapılması için ilgili personelin eğitim alması değerlendirilmelidir.

İhlal çözümlendikten sonra gözetim işlevi için ihlale cevaben yapılan işlemler mutlaka kayıt altına alınmalıdır (log). İhlalin kök sebebi bulunmalı ve gerekli düzeltici/iyileştirici faaliyetler gerçekleştirilmelidir. Kurum her ihlalden bir şey “öğrenmelidir”.

1.9. Bilgi Güvenliđi Yönetiminin Değerlendirilmesi

Kurumda bilgi güvenliđi yönetimi değerlendirilirken, diğerk bölümlerde olduđu gibi burada da ilk önce ilgili tüm politika ve prosedürler incelenmeli, daha sonra da genel olarak işletmedeki bilgi güvenliđi farkındalıđı değerlendirilmelidir.

Bilgi güvenliđi ve varsa destek politikalarının yazılı, üst yönetimce onaylanmış, tüm personele duyurulmuş ve düzenli olarak gözden geçirilmekte olup olmadığı hususu incelenmelidir. Yazılı, onaylı ve duyurulmuş bilgi güvenliđi politikası olmaması veya bunun duyurulmaması risk yaratır. Bilgi güvenliđi politikası sadece bilgi sistemleri birimine deđil, tüm çalışanlara duyurulmuş olmalı ve her an erişilebilir yerde olmalıdır. Bunun yanı sıra yukarıda detayları belirtilen süreçlerin yazılı ve onaylı dokümantasyonda mevcut olduđu, bunların etkin bir şekilde işletildiđi ve sahada karşılığının olduđu değerlendirilmelidir. Değerlendirme sırasında mümkün olduđu kadar kanıt toplanmalıdır.

Bilgi güvenliđi ile ilgili çalışanlara verilen/aldırılan eğitim kayıtları incelenmelidir. Tüm personel en az bir kere eğitim almış olmalıdır.

Risk yönetim süreci değerlendirilirken geçmiş risk değerlendirmelerin sonuçlarına bakılmalı (mutlaka yazılı olarak mevcut olmalıdır), kabul edilebilir risk seviyesinin yönetimce onaylanıp onaylanmadığı gözden geçirilmelidir. Risk işleme süreci kontrol edilmeli, risk azaltma kararı verilen varlıklarla ilgili yapılacakların belli olup olmadığı (ne yapılacak, kim yapacak, ne zamana kadar yapacak) incelenmelidir.

Bilgi güvenliđinin izleme/ölçme süreci incelenmeli, ölçüm sonuçlarının üst yönetimce değerlendirilip değerlendirilmediđi hususuna dikkat edilmelidir.

İhlal yönetim süreci değerlendirilirken geçmiş ihlal kayıtlarına bakılmalı, özellikle ihlalden kimin haberdar edildiđi, toplanan kanıtlar, ihlale cevaben yapılan işlemler ve kök sebebin tespit edilip edilmediđi incelenmelidir.

Örnek Sorular

Soru 1: Aşağıdakilerden hangisi risk işleme seçeneklerinden değildir?

- A) Riski Azaltma
- B) Riski Engelleme
- C) Riski Paylaşma
- D) Riski Öngörme
- E) Riski Kabul Etme

Cevap: D

Soru 2: Aşağıdakilerden hangisi bilgi güvenliğinin üç temel özelliğidir?

- A) Bütünlük-Kimlik Doğrulama-Erişilebilirlik
- B) Gizlilik-Bütünlük-Yetkilendirme
- C) Erişilebilirlik-Bütünlük-Gizlilik
- D) Hesap Verebilirlik-İnkâr Edilemezlik-Gizlilik
- E) Hesap Verebilirlik-İnkâr Edilemezlik-Erişilebilirlik

Cevap: C